



# FindMyFlick ZAP Report3

Sites: <https://telem-edge.smartscreen.microsoft.com> <https://data-edge.smartscreen.microsoft.com> <https://nav-edge.smartscreen.microsoft.com> <https://www.findmyflick.com> <http://www.findmyflick.com>

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

## Summary of Alerts

| Risk Level    | Number of Alerts |
|---------------|------------------|
| High          | 0                |
| Medium        | 4                |
| Low           | 3                |
| Informational | 2                |

## Alerts

| Name                                                          | Risk Level    | Number of Instances |
|---------------------------------------------------------------|---------------|---------------------|
| <a href="#">CSP: Wildcard Directive</a>                       | Medium        | 2                   |
| <a href="#">CSP: style-src unsafe-inline</a>                  | Medium        | 2                   |
| <a href="#">Content Security Policy (CSP) Header Not Set</a>  | Medium        | 1                   |
| <a href="#">Sub Resource Integrity Attribute Missing</a>      | Medium        | 5                   |
| <a href="#">Cross-Domain JavaScript Source File Inclusion</a> | Low           | 3                   |
| <a href="#">Strict-Transport-Security Header Not Set</a>      | Low           | 5                   |
| <a href="#">X-Content-Type-Options Header Missing</a>         | Low           | 4                   |
| <a href="#">Information Disclosure - Suspicious Comments</a>  | Informational | 1                   |
| <a href="#">Modern Web Application</a>                        | Informational | 3                   |

## Alert Detail

| Medium      | CSP: Wildcard Directive                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|-------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description | Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files. |
| URL         | <a href="http://www.findmyflick.com">http://www.findmyflick.com</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Node Name  | http://www.findmyflick.com                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence   | default-src 'self'; script-src 'self' static.cloudflareinsights.com; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; connect-src 'self' https://findmyflick-api-ecargjhzf4acffec.canadacentral-01.azurewebsites.net https://cloudflareinsights.com; font-src 'self' data:; object-src 'none'; frame-ancestors 'none'; base-uri 'self'; form-action 'self'                                                                                                                                |
| Other Info | The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined:<br><br>img-src                                                                                                                                                                                                                                                                                                                                                                   |
| URL        | <a href="https://www.findmyflick.com/">https://www.findmyflick.com/</a>                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Node Name  | https://www.findmyflick.com/                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence   | default-src 'self'; script-src 'self' static.cloudflareinsights.com; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; connect-src 'self' https://findmyflick-api-ecargjhzf4acffec.canadacentral-01.azurewebsites.net https://cloudflareinsights.com; font-src 'self' data:; object-src 'none'; frame-ancestors 'none'; base-uri 'self'; form-action 'self'                                                                                                                                |
| Other Info | The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined:<br><br>img-src                                                                                                                                                                                                                                                                                                                                                                   |
| Instances  | 2                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Solution   | Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.                                                                                                                                                                                                                                                                                                                                                                  |
| Reference  | <a href="https://www.w3.org/TR/CSP/">https://www.w3.org/TR/CSP/</a><br><a href="https://caniuse.com/#search=content+security+policy">https://caniuse.com/#search=content+security+policy</a><br><a href="https://content-security-policy.com/">https://content-security-policy.com/</a><br><a href="https://github.com/HtmlUnit/htmlunit-csp">https://github.com/HtmlUnit/htmlunit-csp</a><br><a href="https://web.dev/articles/csp#resource-options">https://web.dev/articles/csp#resource-options</a> |
| CWE Id     | <a href="#">693</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| WASC Id    | 15                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Plugin Id  | <a href="#">10055</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |

|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Medium      | <b>CSP: style-src unsafe-inline</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Description | Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files. |
| URL         | <a href="http://www.findmyflick.com">http://www.findmyflick.com</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Node Name   | http://www.findmyflick.com                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Evidence    | default-src 'self'; script-src 'self' static.cloudflareinsights.com; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; connect-src 'self' https://findmyflick-api-ecargjhzf4acffec.canadacentral-01.azurewebsites.net https://cloudflareinsights.com; font-src 'self' data:; object-src 'none'; frame-ancestors 'none'; base-uri 'self'; form-action 'self'                                                                                                                                                                                                                                                           |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Other Info | style-src includes unsafe-inline.                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| URL        | <a href="https://www.findmyflick.com/">https://www.findmyflick.com/</a>                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Node Name  | https://www.findmyflick.com/                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence   | default-src 'self'; script-src 'self' static.cloudflareinsights.com; style-src 'self' 'unsafe-inline'; img-src 'self' data: https;; connect-src 'self' https://findmyflick-api-ecargjhzf4acffec.canadacentral-01.azurewebsites.net https://cloudflareinsights.com; font-src 'self' data;; object-src 'none'; frame-ancestors 'none'; base-uri 'self'; form-action 'self'                                                                                                                                |
| Other Info | style-src includes unsafe-inline.                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Instances  | 2                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Solution   | Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.                                                                                                                                                                                                                                                                                                                                                                  |
| Reference  | <a href="https://www.w3.org/TR/CSP/">https://www.w3.org/TR/CSP/</a><br><a href="https://caniuse.com/#search=content+security+policy">https://caniuse.com/#search=content+security+policy</a><br><a href="https://content-security-policy.com/">https://content-security-policy.com/</a><br><a href="https://github.com/HtmlUnit/htmlunit-csp">https://github.com/HtmlUnit/htmlunit-csp</a><br><a href="https://web.dev/articles/csp#resource-options">https://web.dev/articles/csp#resource-options</a> |
| CWE Id     | <a href="#">693</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| WASC Id    | 15                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Plugin Id  | <a href="#">10055</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |

|               |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|---------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Medium</b> | <b>Content Security Policy (CSP) Header Not Set</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Description   | Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.                                                                                                                                                                                      |
| URL           | <a href="https://www.findmyflick.com/sitemap.xml">https://www.findmyflick.com/sitemap.xml</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Node Name     | https://www.findmyflick.com/sitemap.xml                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Method        | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Attack        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Evidence      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Other Info    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Instances     | 1                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Solution      | Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Reference     | <a href="https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP">https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP</a><br><a href="https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html">https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html</a><br><a href="https://www.w3.org/TR/CSP/">https://www.w3.org/TR/CSP/</a><br><a href="https://w3c.github.io/webappsec-csp/">https://w3c.github.io/webappsec-csp/</a><br><a href="https://web.dev/articles/csp">https://web.dev/articles/csp</a><br><a href="https://caniuse.com/#feat=contentsecuritypolicy">https://caniuse.com/#feat=contentsecuritypolicy</a><br><a href="https://content-security-policy.com/">https://content-security-policy.com/</a> |
| CWE Id        | <a href="#">693</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |

|           |                       |
|-----------|-----------------------|
| WASC Id   | 15                    |
| Plugin Id | <a href="#">10038</a> |

| Medium      | Sub Resource Integrity Attribute Missing                                                                                                                                                                  |
|-------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description | The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content. |
| URL         | <a href="https://www.findmyflick.com/sitemap.xml">https://www.findmyflick.com/sitemap.xml</a>                                                                                                             |
| Node Name   | https://www.findmyflick.com/sitemap.xml                                                                                                                                                                   |
| Method      | GET                                                                                                                                                                                                       |
| Attack      |                                                                                                                                                                                                           |
| Evidence    | <link rel=stylesheet href=https://ajax.aspnetcdn.com/ajax/bootstrap/5.2.3/css/bootstrap.min.css crossorigin=anonymous />                                                                                  |
| Other Info  |                                                                                                                                                                                                           |
| URL         | <a href="https://www.findmyflick.com/sitemap.xml">https://www.findmyflick.com/sitemap.xml</a>                                                                                                             |
| Node Name   | https://www.findmyflick.com/sitemap.xml                                                                                                                                                                   |
| Method      | GET                                                                                                                                                                                                       |
| Attack      |                                                                                                                                                                                                           |
| Evidence    | <link rel=stylesheet type=text/css href="https://appservice.azureedge.net/css/static-apps/v3/main.css"/>                                                                                                  |
| Other Info  |                                                                                                                                                                                                           |
| URL         | <a href="https://www.findmyflick.com/sitemap.xml">https://www.findmyflick.com/sitemap.xml</a>                                                                                                             |
| Node Name   | https://www.findmyflick.com/sitemap.xml                                                                                                                                                                   |
| Method      | GET                                                                                                                                                                                                       |
| Attack      |                                                                                                                                                                                                           |
| Evidence    | <script src=https://ajax.aspnetcdn.com/ajax/bootstrap/5.2.3/bootstrap.min.js crossorigin=anonymous></script>                                                                                              |
| Other Info  |                                                                                                                                                                                                           |
| URL         | <a href="https://www.findmyflick.com/sitemap.xml">https://www.findmyflick.com/sitemap.xml</a>                                                                                                             |
| Node Name   | https://www.findmyflick.com/sitemap.xml                                                                                                                                                                   |
| Method      | GET                                                                                                                                                                                                       |
| Attack      |                                                                                                                                                                                                           |
| Evidence    | <script src=https://ajax.aspnetcdn.com/ajax/jquery/jquery-3.7.1.min.js crossorigin=anonymous></script>                                                                                                    |
| Other Info  |                                                                                                                                                                                                           |
| URL         | <a href="https://www.findmyflick.com/sitemap.xml">https://www.findmyflick.com/sitemap.xml</a>                                                                                                             |
| Node Name   | https://www.findmyflick.com/sitemap.xml                                                                                                                                                                   |
| Method      | GET                                                                                                                                                                                                       |
| Attack      |                                                                                                                                                                                                           |

|            |                                                                                                                                                                       |
|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Evidence   | <script src=https://appservice.azureedge.net/scripts/static-apps/v3/loc.min.js crossorigin=anonymous></script>                                                        |
| Other Info |                                                                                                                                                                       |
| Instances  | 5                                                                                                                                                                     |
| Solution   | Provide a valid integrity attribute to the tag.                                                                                                                       |
| Reference  | <a href="https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity">https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity</a> |
| CWE Id     | <a href="#">345</a>                                                                                                                                                   |
| WASC Id    | 15                                                                                                                                                                    |
| Plugin Id  | <a href="#">90003</a>                                                                                                                                                 |

|             |                                                                                                                                           |
|-------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Low</b>  | <b>Cross-Domain JavaScript Source File Inclusion</b>                                                                                      |
| Description | The page includes one or more script files from a third-party domain.                                                                     |
| URL         | <a href="https://www.findmyflick.com/sitemap.xml">https://www.findmyflick.com/sitemap.xml</a>                                             |
| Node Name   | https://www.findmyflick.com/sitemap.xml                                                                                                   |
| Method      | GET                                                                                                                                       |
| Attack      |                                                                                                                                           |
| Evidence    | <script src=https://ajax.aspnetcdn.com/ajax/bootstrap/5.2.3/bootstrap.min.js crossorigin=anonymous></script>                              |
| Other Info  |                                                                                                                                           |
| URL         | <a href="https://www.findmyflick.com/sitemap.xml">https://www.findmyflick.com/sitemap.xml</a>                                             |
| Node Name   | https://www.findmyflick.com/sitemap.xml                                                                                                   |
| Method      | GET                                                                                                                                       |
| Attack      |                                                                                                                                           |
| Evidence    | <script src=https://ajax.aspnetcdn.com/ajax/jquery/jquery-3.7.1.min.js crossorigin=anonymous></script>                                    |
| Other Info  |                                                                                                                                           |
| URL         | <a href="https://www.findmyflick.com/sitemap.xml">https://www.findmyflick.com/sitemap.xml</a>                                             |
| Node Name   | https://www.findmyflick.com/sitemap.xml                                                                                                   |
| Method      | GET                                                                                                                                       |
| Attack      |                                                                                                                                           |
| Evidence    | <script src=https://appservice.azureedge.net/scripts/static-apps/v3/loc.min.js crossorigin=anonymous></script>                            |
| Other Info  |                                                                                                                                           |
| Instances   | 3                                                                                                                                         |
| Solution    | Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application. |
| Reference   |                                                                                                                                           |
| CWE Id      | <a href="#">829</a>                                                                                                                       |
| WASC Id     | 15                                                                                                                                        |
| Plugin Id   | <a href="#">10017</a>                                                                                                                     |

| Low         | Strict-Transport-Security Header Not Set                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description | HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.                                                                                                                                                                                                                                                                              |
| URL         | <a href="https://www.findmyflick.com/sitemap.xml">https://www.findmyflick.com/sitemap.xml</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Node Name   | https://www.findmyflick.com/sitemap.xml                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Evidence    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Other Info  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| URL         | <a href="https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3">https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3</a>                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Node Name   | https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3 ()({identity: {user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},correlationId,debugInfo:{clientId}})                                                                                                                                                                                            |
| Method      | POST                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Evidence    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Other Info  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| URL         | <a href="https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3">https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3</a>                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Node Name   | https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3 ()({identity: {user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},correlationId,debugInfo:{clientId}})                                                                                                                                                                                          |
| Method      | POST                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Evidence    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Other Info  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| URL         | <a href="https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3">https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Node Name   | https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3 ()({userAgent,redirectChain:[],enhancedRedirectChain:{redirectSource,referrerChain:[]},identity:{user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},config:{user:{uriReputation:{enforcedByPolicy,level}},device:{appControl:{level},appReputation:{enforcedByPolicy,level}}},destination:{uri,ip},...) |
| Method      | POST                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Evidence    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Other Info  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| URL         | <a href="https://telem-edge.smartscreen.microsoft.com/api/browser/edge/telemetry/3">https://telem-edge.smartscreen.microsoft.com/api/browser/edge/telemetry/3</a>                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|             | https://telem-edge.smartscreen.microsoft.com/api/browser/edge/telemetry/3 ()                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Node Name  | {{executionTime,random,samplingRates:{evaluateModel,serverCall},config:{user:{uriReputation:{enforcedByPolicy,level}},device:{appControl:{level},appReputation:{enforcedByPolicy,level}}},correlationId,identity:{user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},userAgent,events:[{\$type,nam...}}                                                                                                                                                            |
| Method     | POST                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Instances  | 5                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Solution   | Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Reference  | <a href="https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html">https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html</a><br><a href="https://owasp.org/www-community/Security-Headers">https://owasp.org/www-community/Security-Headers</a><br><a href="https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security">https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security</a><br><a href="https://caniuse.com/stricttransportsecurity">https://caniuse.com/stricttransportsecurity</a><br><a href="https://datatracker.ietf.org/doc/html/rfc6797">https://datatracker.ietf.org/doc/html/rfc6797</a> |
| CWE Id     | <a href="#">319</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| WASC Id    | 15                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Plugin Id  | <a href="#">10035</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |

|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|-------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Low</b>  | <b>X-Content-Type-Options Header Missing</b>                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Description | The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing. |
| URL         | <a href="http://www.findmyflick.com/robots.txt">http://www.findmyflick.com/robots.txt</a>                                                                                                                                                                                                                                                                                                                                                                            |
| Node Name   | http://www.findmyflick.com/robots.txt                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Method      | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Evidence    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Other Info  | This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.<br><br>At "High" threshold this scan rule will not alert on client or server error responses.                                                                                                                                  |
| URL         | <a href="https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3">https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3</a>                                                                                                                                                                                                                                                                                              |
| Node Name   | https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3 ()({identity:{user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},correlationId,debugInfo:{clientId}})                                                      |
| Method      | POST                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Attack      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Evidence    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Other Info | <p>This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.</p> <p>At "High" threshold this scan rule will not alert on client or server error responses.</p>                                                                                                                                                                                                                                                                              |
| URL        | <a href="https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3">https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3</a>                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Node Name  | <code>https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3 ()({identity: {user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUri,edgeSettings,customSettings}}},correlationId,debugInfo:{clientId}})</code>                                                                                                                                                                                          |
| Method     | POST                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Other Info | <p>This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.</p> <p>At "High" threshold this scan rule will not alert on client or server error responses.</p>                                                                                                                                                                                                                                                                              |
| URL        | <a href="https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3">https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Node Name  | <code>https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3 ()({userAgent,redirectChain:[],enhancedRedirectChain:{redirectSource,referrerChain:[]},identity:{user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUri,edgeSettings,customSettings}}},config:{user:{uriReputation:{enforcedByPolicy,level}},device:{appControl:{level},appReputation:{enforcedByPolicy,level}}},destination:{uri,ip},...)</code> |
| Method     | POST                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Other Info | <p>This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.</p> <p>At "High" threshold this scan rule will not alert on client or server error responses.</p>                                                                                                                                                                                                                                                                              |
| Instances  | 4                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Solution   | <p>Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.</p> <p>If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.</p>                                                                                                                                                                                                        |
| Reference  | <a href="https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)">https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)</a><br><a href="https://owasp.org/www-community/Security_Headers">https://owasp.org/www-community/Security_Headers</a>                                                                                                                                                                                                                                  |
| CWE Id     | <a href="#">693</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| WASC Id    | 15                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Plugin Id  | <a href="#">10021</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |

| Informational | Information Disclosure - Suspicious Comments                                                                            |
|---------------|-------------------------------------------------------------------------------------------------------------------------|
| Description   | The response appears to contain suspicious comments which may help an attacker.                                         |
| URL           | <a href="https://www.findmyflick.com/assets/index-DQxa05tj.js">https://www.findmyflick.com/assets/index-DQxa05tj.js</a> |
| Node Name     | <code>https://www.findmyflick.com/assets/index-DQxa05tj.js</code>                                                       |
|               |                                                                                                                         |



|            |                                                                                                                                                                                                                                                                                                   |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Method     | GET                                                                                                                                                                                                                                                                                               |
| Attack     |                                                                                                                                                                                                                                                                                                   |
| Evidence   | or(`Failed to fetch user`);r(await t.json())                                                                                                                                                                                                                                                      |
| Other Info | The following pattern was used: <code>\bUSER\b</code> and was detected in likely comment: <code>"//,``).split('/')`);h=`'+m.replace(/^\//,``).split(`').slice(e.length).join(`')}`let g=oe(e,{pathname:h});T(d  g!=null,`No route", see evidence field for the suspicious comment/snippet.</code> |
| Instances  | 1                                                                                                                                                                                                                                                                                                 |
| Solution   | Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.                                                                                                                                                                              |
| Reference  |                                                                                                                                                                                                                                                                                                   |
| CWE Id     | <a href="#">615</a>                                                                                                                                                                                                                                                                               |
| WASC Id    | 13                                                                                                                                                                                                                                                                                                |
| Plugin Id  | <a href="#">10027</a>                                                                                                                                                                                                                                                                             |

| Informational | Modern Web Application                                                                                                                                                 |
|---------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description   | The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one. |
| URL           | <a href="http://www.findmyflick.com">http://www.findmyflick.com</a>                                                                                                    |
| Node Name     | http://www.findmyflick.com                                                                                                                                             |
| Method        | GET                                                                                                                                                                    |
| Attack        |                                                                                                                                                                        |
| Evidence      | <code>&lt;script type="module" crossorigin src="/assets/index-DQxa05tj.js"&gt;&lt;/script&gt;</code>                                                                   |
| Other Info    | No links have been found while there are scripts, which is an indication that this is a modern web application.                                                        |
| URL           | <a href="https://www.findmyflick.com/">https://www.findmyflick.com/</a>                                                                                                |
| Node Name     | https://www.findmyflick.com/                                                                                                                                           |
| Method        | GET                                                                                                                                                                    |
| Attack        |                                                                                                                                                                        |
| Evidence      | <code>&lt;script type="module" crossorigin src="/assets/index-DQxa05tj.js"&gt;&lt;/script&gt;</code>                                                                   |
| Other Info    | No links have been found while there are scripts, which is an indication that this is a modern web application.                                                        |
| URL           | <a href="https://www.findmyflick.com/sitemap.xml">https://www.findmyflick.com/sitemap.xml</a>                                                                          |
| Node Name     | https://www.findmyflick.com/sitemap.xml                                                                                                                                |
| Method        | GET                                                                                                                                                                    |
| Attack        |                                                                                                                                                                        |
| Evidence      | <code>&lt;script src=https://appservice.azureedge.net/scripts/static-apps/v3/loc.min.js crossorigin=anonymous&gt;&lt;/script&gt;</code>                                |
| Other Info    | No links have been found while there are scripts, which is an indication that this is a modern web application.                                                        |
| Instances     | 3                                                                                                                                                                      |
| Solution      | This is an informational alert and so no changes are required.                                                                                                         |
| Reference     |                                                                                                                                                                        |
| CWE Id        |                                                                                                                                                                        |
| WASC Id       |                                                                                                                                                                        |

|           |                       |
|-----------|-----------------------|
| Plugin Id | <a href="#">10109</a> |
|-----------|-----------------------|